To refresh an access token, the client calls the AS token endpoint passing in the refresh token, using the *refresh token grant*, and sending the refresh token and any client credentials, as in the following example:

```
$ curl -d 'grant_type=refresh_token    #A
[CA]&refresh_token=sBac5bgCLCjWmtjQ8Weji2mCrbI'    #A
[CA]-u test:password     #B
[CA]https://as.example.com:8443/oauth2/access_token
{
  "access_token":"snGxj86QSYB7Zojt3G1b2aXN5UM",    #C
  "scope":"post_message read_messages",
  "token_type":"Bearer","expires_in":3599}
```

#A Use the refresh token grant and supply the refresh token.
#B Include client credentials if using a confidential client.
#C The AS returns a fresh access token.

The AS can often be configured to issue a new refresh token at the same time (revoking the old one), enforcing that each refresh token is used only once. This can be used to detect refresh token theft: when the attacker uses the refresh token, it will stop working for the legitimate client.

7.4 Validating an access token

Now that you've learned how to obtain an access token for a client, you need to learn how to validate the token in your API. In previous chapters, it was simple to look up a token in the local token database. For OAuth2, this is no longer quite so simple when tokens are issued by the AS and not by the API. Although you could share a token database between